Information Security Policy

Document control	
Company	LogistiComp S.A.
Document ID	LC-POL-001
Version	3.1
Classification	Internal – may be shared with customers under NDA
Owner	Chief Information Security Officer (CISO)
Approved by	Information Security Steering Committee (ISSC)
Effective date	15 January 2026
Next review	January 2027

1. Purpose

This policy sets out how LogistiComp S.A. ("LogistiComp", "the Company") protects the confidentiality, integrity and availability of the information it holds, including the data our customers entrust to us. It defines the principles, responsibilities and minimum controls of the Company's Information Security Management System (ISMS). More detailed requirements are set out in the topic-specific policies listed in Section 20.

2. Scope

This policy applies to:

- all employees, contractors, temporary staff and interns of LogistiComp;
- third parties who access LogistiComp information or systems;
- the LogistiComp WMS production environment, the development and test environments, and the Company's corporate IT systems;
- the Company's offices in Athens and Thessaloniki, and remote working locations.

3. Company and Service Overview

LogistiComp is headquartered in Athens, Greece, and employs about 180 people. The Company develops and operates **LogistiComp WMS**, a multi-tenant software-as-a-service (SaaS) warehouse management system used by third-party logistics providers (3PLs) and distributors. LogistiComp WMS covers inventory management, receiving, picking and packing, shipping and carrier integration, and integration with customers' ERP and EDI systems.

The production environment is hosted on **Microsoft Azure**. The primary region is West Europe (Netherlands) and the secondary region, used for disaster recovery, is North

Europe (Ireland). LogistiComp does not own or operate data centres. Customer data is stored and processed only within the European Union.

4. Roles and Responsibilities

- **Chief Executive Officer (CEO):** accountable for information security and for providing the resources the ISMS needs.
- **Chief Information Security Officer (CISO):** owns this policy and the ISMS, maintains the risk register, reports to the CEO and chairs the ISSC.
- **Information Security Steering Committee (ISSC):** meets quarterly and consists of the CEO, the CISO, the Chief Technology Officer (CTO), the Head of Customer Operations and the Data Protection Officer (DPO). The ISSC approves security policies, risk treatment plans and major security investments.
- **Data Protection Officer (DPO):** oversees compliance with data protection law (see the Privacy Policy, LC-POL-006).
- **Engineering managers:** ensure that their teams follow the secure development and change management requirements.
- **All personnel:** follow this policy, protect the information they handle and report suspected security incidents immediately.

5. Information Security Management System and Certifications

LogistiComp operates an ISMS aligned with ISO/IEC 27001. The Company has been **certified to ISO/IEC 27001:2022 since 2023**. The certification scope covers the development, operation and support of LogistiComp WMS. Surveillance audits are performed annually by an accredited certification body, and recertification takes place every three years. A copy of the certificate is available to customers on request.

LogistiComp does **not** yet hold a SOC 2 report. A SOC 2 Type II audit is under way: the observation period started in October 2026, and the report is expected in the second quarter of 2027.

The ISMS is audited internally once a year. Findings are tracked to closure by the CISO and reported to the ISSC.

6. Risk Management

Information security risks are assessed at least annually and whenever a significant change occurs, such as a new major product feature, a new hosting region or a new critical supplier. Risks are scored on a five-by-five scale of likelihood and impact and recorded in the risk register maintained by the CISO. Every risk rated "High" or above must have a treatment plan approved by the ISSC within 30 days of being identified.

7. Information Classification

All information is classified into one of four levels:

Level	Description	Examples
Public	Approved for public release	Marketing material, public website
Internal	For use within LogistiComp	Internal procedures, organisation charts
Confidential	Sensitive business information	Contracts, financial reports, source code
Restricted	Highest sensitivity; unauthorised disclosure could cause serious harm	Customer data, credentials, encryption keys

All customer data processed in LogistiComp WMS, including inventory, order and shipment data and any personal data, is classified as **Restricted**. Restricted information may only be accessed by authorised personnel with a business need, must be encrypted in storage and in transit (see LC-POL-008), and must not be copied to removable media (see LC-POL-010).

8. Human Resources Security

- **Screening:** background verification is carried out before employment starts, where permitted by law. It includes identity and employment history checks and, for roles with access to the production environment, a criminal record check.
- **Confidentiality:** every employee and contractor signs a confidentiality agreement before receiving access to any LogistiComp system.
- **Training:** all personnel complete security awareness training within 30 days of joining and annually thereafter. Completion is tracked by the CISO. Phishing simulation exercises are run quarterly.
- **Disciplinary process:** violations of this policy are handled through the Company's disciplinary process.
- **Leaving the Company:** all access rights are revoked no later than the end of the person's last working day, and all Company equipment must be returned.

9. Access Control

Access to information and systems is granted on the principles of least privilege and need-to-know, using role-based access control.

- Multi-factor authentication (MFA) is required for all workforce access to corporate and production systems.
- Access to the production environment is only possible with named personal accounts, through a bastion host with just-in-time privileged access. All privileged sessions are logged.
- Access rights to the production environment are reviewed quarterly. Access rights to all other systems are reviewed every six months.

Detailed requirements, including password rules, are defined in the Access Control and Password Policy (LC-POL-002).

10. Physical and Environmental Security

LogistiComp offices are protected by badge-controlled entry. Visitors must be registered at reception and escorted at all times, and CCTV covers office entrances. No customer data is stored on servers located in LogistiComp offices.

Physical and environmental security of the production environment is provided by Microsoft Azure data centres, whose controls are covered by Microsoft's own independent certifications and audit reports.

11. Operations Security

11.1 Endpoint Security

Employees use Company-managed laptops with full-disk encryption, endpoint detection and response (EDR) software and automatic operating system updates. Personal devices are not permitted to access the production environment.

11.2 Vulnerability and Patch Management

Automated vulnerability scans of the production environment and corporate systems run weekly. Identified vulnerabilities must be remediated within the following time limits, counted from the date of identification:

Severity	Remediation time limit
Critical	7 days
High	30 days
Medium	90 days
Low	Best effort, normally in the next scheduled release

If a time limit cannot be met, an exception must be approved under Section 18.

11.3 Logging and Monitoring

Security-relevant events, including authentication events, privileged actions and configuration changes, are collected centrally in a security information and event management (SIEM) system. The SIEM is monitored 24 hours a day, 7 days a week by a managed security operations centre (SOC) provider. Security event logs are retained for at least 12 months in write-once storage, which protects them against modification or deletion.

11.4 Malware Protection

All endpoints and servers run anti-malware protection that is updated automatically. Email is filtered for malicious attachments and links before delivery.

12. Secure Development

LogistiComp WMS is developed according to a secure software development lifecycle:

- every code change is peer-reviewed by at least one engineer other than its author before it is merged;
- static application security testing (SAST) and dependency vulnerability scanning run automatically in the build pipeline, and critical findings block the release;
- secrets such as passwords and API keys are never stored in source code; they are kept in Azure Key Vault;
- development, test and production environments are separated, and production customer data is not used in development or test environments.

Changes are deployed to production according to the Change Management Policy (LC-POL-007).

13. Penetration Testing

An external penetration test of LogistiComp WMS, covering both the web application and its APIs, is performed annually by an independent, CREST-accredited testing firm. Additional tests are performed after major architectural changes. Findings are remediated within the time limits in Section 11.2.

14. Supplier Security

Suppliers that access LogistiComp information or systems, or that process customer data on the Company's behalf, are assessed before contracting and reviewed periodically, as defined in the Vendor and Third-Party Management Policy (LC-POL-009).

15. Incident Management

All personnel must report suspected security incidents immediately to the security team at security@logisticomp.example. Incidents are handled according to the Incident Response Policy (LC-POL-003).

16. Business Continuity

Business continuity and disaster recovery requirements, including recovery objectives for LogistiComp WMS, are defined in the Business Continuity and Disaster Recovery Policy (LC-POL-004).

17. Compliance

LogistiComp complies with applicable laws and regulations, including the EU General Data Protection Regulation (GDPR) and Greek Law 4624/2019, as well as with its contractual obligations to customers. Compliance with this policy is verified through the annual internal ISMS audit and the external certification audits described in Section 5.

18. Exceptions

Exceptions to this policy must be requested in writing, risk-assessed and approved by the CISO. Approved exceptions are recorded in the exceptions register and are valid for a maximum of 12 months, after which they must be reviewed again.

19. Enforcement

Failure to comply with this policy may result in disciplinary action, up to and including termination of employment or contract.

20. Review and Related Documents

This policy is reviewed at least annually by the CISO and approved by the ISSC.

Related documents:

- LC-POL-002 Access Control and Password Policy
- LC-POL-003 Incident Response Policy
- LC-POL-004 Business Continuity and Disaster Recovery Policy
- LC-POL-005 Backup and Data Retention Policy
- LC-POL-006 Privacy Policy
- LC-POL-007 Change Management Policy
- LC-POL-008 Encryption and Key Management Policy
- LC-POL-009 Vendor and Third-Party Management Policy
- LC-POL-010 Removable Media Policy